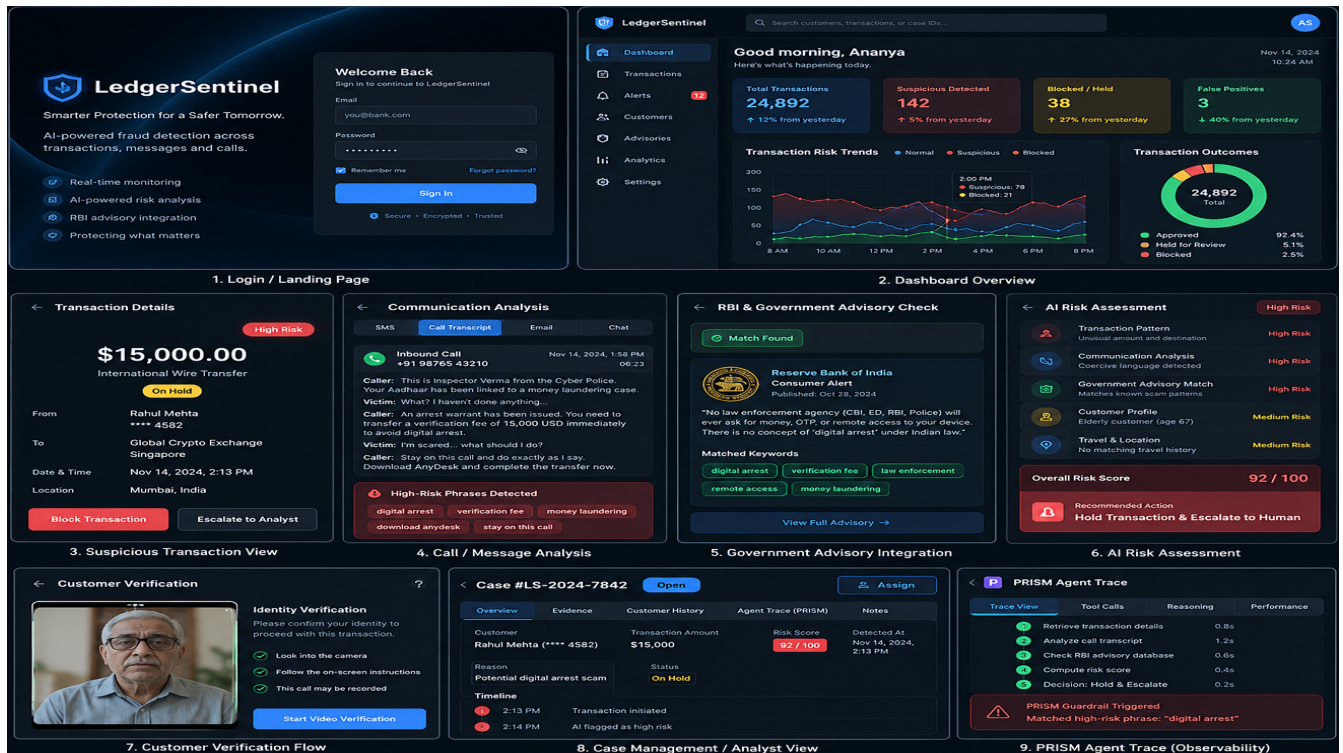


# LEDGERSENTINEL

Autonomous Fraud Detection & Bounded-Action Agent

Wireframes & UI/UX • Design System • Technical Architecture • APIs • Security • Roadmap • GTM • Analytics • Full PRD



Frontend concept collage for the prototype.

**Core thesis: When AI isn't certain, it should become less autonomous — not more confident.**

Version 1.0 • Hackathon build specification • September 2026

# 1. Executive Summary

LedgerSentinel is an AI-assisted fraud-response platform that evaluates a financial transaction together with the context surrounding it. It combines structured signals such as amount, destination, customer history and location with unstructured evidence such as SMS, email, chat and call transcripts.

The key problem is social engineering: a customer may be the person technically authorizing a transaction while simultaneously being manipulated by a scammer. A transaction-only detector can therefore miss a dangerous case. LedgerSentinel looks for the wider context.

The system does not make every decision autonomously. It produces a risk score, a separate confidence estimate, evidence-backed reasoning and a recommended action. A deterministic policy gate then decides the maximum autonomy permitted for that situation.

Action ladder: APPROVE → VERIFY → HOLD → HUMAN ESCALATION. The more consequential or uncertain the case, the less autonomy the system receives.

PRISM is used as the evaluation and observability layer. We build the strongest reasonable V1, run realistic scenarios, observe actual failures, identify root causes, implement a concrete fix, and rerun the same cohort to demonstrate improvement.

The hackathon prototype uses synthetic banking records and curated/public advisory material. It simulates holds and escalations rather than touching real bank accounts.

**Demo promise: show a transaction that looks legitimate in isolation, then show how communication evidence changes the decision and safely reduces the AI's autonomy.**

## 2. Problem Statement, Users & Scope

Financial fraud detection is increasingly good at identifying abnormal transactions, but socially engineered transfers can resemble legitimate behavior. The product opportunity is to combine transaction intelligence with contextual human evidence without turning an LLM into an unrestricted financial operator.

### Primary users

- Fraud analysts: investigate cases and need fast evidence-backed explanations.
- Operations teams: manage verification, holds and escalations.
- Risk/compliance teams: inspect policy adherence, model behavior and audit trails.
- AI engineers: use traces and evaluations to improve the agent.
- Customers: should experience proportionate verification rather than unexplained rejection.

### Hackathon scope

- Synthetic transaction/customer/account dataset.
- Communication analysis for SMS, chat, email and call transcripts.
- RAG over public/curated fraud advisories.
- Evidence fusion, risk + confidence scoring.
- Deterministic action gate with four bounded-action states.
- Analyst dashboard and case-management interface.
- PRISM traces, evaluators, scenario cohort and V1→V2 comparison.

### Out of scope

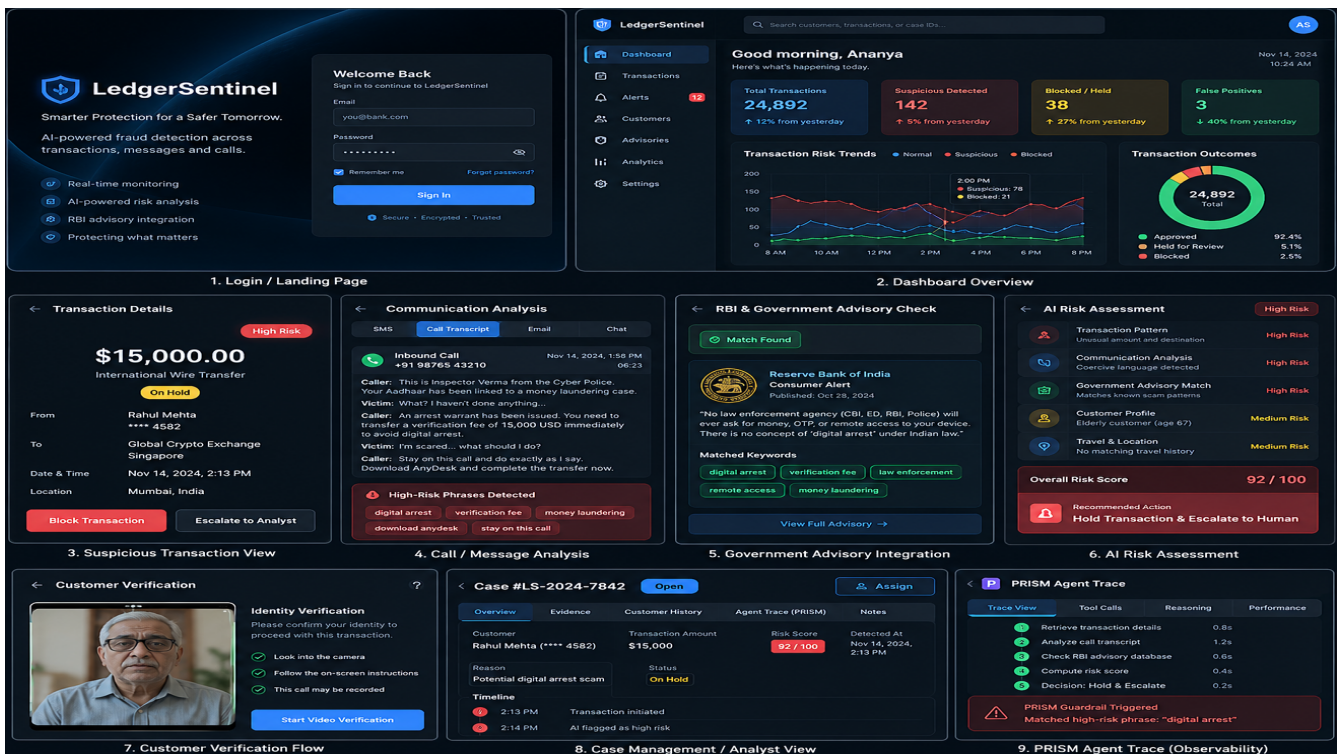
- Real bank account access or real transaction execution.
- Real customer PII in the demonstration.
- Claims of regulatory certification or guaranteed fraud prevention.

- Replacing human fraud/compliance teams.
- Building a full production banking core or telecom infrastructure.

## 3. Wireframes & UI/UX Mockups

The analyst should understand what happened, why it is risky, what evidence supports the assessment, and what action is allowed within seconds.

| Screen                    | Purpose                       | Primary components                                                  |
|---------------------------|-------------------------------|---------------------------------------------------------------------|
| 01 Dashboard              | Portfolio overview            | Risk KPIs, suspicious trend, holds, false positives, recent cases   |
| 02 Transaction Details    | Investigate one transaction   | Amount, origin/destination, timeline, customer context, action      |
| 03 Communication Analysis | Inspect unstructured evidence | Transcript/messages, highlighted risk phrases, signal extraction    |
| 04 Advisory Check         | Inspect external knowledge    | Retrieved advisory, source, matched concepts, provenance            |
| 05 AI Risk Assessment     | Understand decision           | Risk, confidence, factors, evidence links, recommended action       |
| 06 Verification           | Reduce uncertainty            | Customer verification state, safe instructions, verification result |
| 07 Case Management        | Human workflow                | Assignment, evidence, status, notes, audit trail                    |
| 08 PRISM Trace            | Evaluate agent                | Trajectory, tool calls, evaluators, latency, failure/remediation    |



The generated collage is a visual direction; exact implementation can be adapted to the team's chosen frontend stack.

## 4. Design System & UI Guidelines

Visual language: dark fintech surfaces, high contrast, restrained decoration, compact data cards, explicit risk states and strong hierarchy. The UI should communicate urgency without creating unnecessary panic.

| Token      | Guideline           | Usage                                       |
|------------|---------------------|---------------------------------------------|
| Primary    | Blue / action       | Navigation, primary buttons, selected tabs  |
| Success    | Green / safe        | Approved, verified, resolved                |
| Warning    | Amber / uncertainty | Verification required, medium confidence    |
| Danger     | Red / critical      | Hold, escalation, critical evidence         |
| Neutral    | Slate / context     | Metadata, secondary information             |
| Typography | 8–28 px hierarchy   | Dense data + readable headings              |
| Spacing    | 4/8 px rhythm       | Cards, panels, controls                     |
| Radius     | 8–14 px             | Cards and controls; avoid excessive pill UI |

### UX principles

- Never show a risk score without the factors behind it.
- Separate risk from confidence; uncertainty is itself a decision signal.
- Use explicit actions: “Hold & Escalate” is clearer than “Block.”
- Color must never be the only indicator of status.
- High-impact actions require confirmation and configured human approval.
- External text is evidence, not an instruction to the agent.
- Every decision must have traceable provenance.

## 5. Technical Architecture

| Layer         | Technology / Component             | Responsibility                                    |
|---------------|------------------------------------|---------------------------------------------------|
| Frontend      | React / Next.js                    | Analyst dashboard, transaction and case workflows |
| API           | FastAPI + REST                     | Ingestion, analysis, cases, decisions             |
| Orchestration | LangGraph / explicit state machine | Bounded agent trajectory                          |
| AI            | LLM + structured extraction        | Reasoning, classification, summarization          |
| Retrieval     | Vector DB + metadata filters       | Public advisory / fraud knowledge                 |
| Policy        | Deterministic action gate          | Enforce autonomy limits                           |
| Data          | PostgreSQL or SQLite prototype     | Customers, transactions, evidence, cases          |
| Observability | PRISM + OpenTelemetry              | Traces, evaluators, regression evidence           |

### End-to-end flow

Transaction → context enrichment → communication analysis → advisory retrieval → evidence normalization → risk + confidence → deterministic action gate → analyst case → audit event → PRISM evaluation.

### Bounded autonomy

- AUTONOMOUS: low-risk, sufficient evidence, within configured limits.
- VERIFY: moderate risk or uncertainty; request controlled verification.
- HOLD: elevated risk; simulate temporary hold and route to review.
- HUMAN ESCALATION: high-impact, high-risk or conflicting evidence.

## Agent containment

- Typed tool interfaces and allowlists.
- Maximum tool calls, retrieval depth and execution time.
- Explicit terminal states instead of open-ended loops.
- Structured evidence objects instead of free-form justifications.
- Policy gate can reject an AI recommendation regardless of model confidence.
- Decision stores model, policy, trace and evidence references.

## 6. Data Model & Evidence Schema

| Entity        | Representative fields                                                                  |
|---------------|----------------------------------------------------------------------------------------|
| Customer      | customer_id, age_band, account_age, verification_status, profile                       |
| Account       | account_id, customer_id, balance_band, country, normal_activity                        |
| Transaction   | transaction_id, account_id, amount, currency, destination, timestamp, location, device |
| Communication | communication_id, customer_id, channel, timestamp, text/transcript, extracted_signals  |
| Evidence      | evidence_id, source_type, source_ref, claim, confidence, timestamp                     |
| Advisory      | advisory_id, publisher, title, published_at, content, tags                             |
| Assessment    | assessment_id, transaction_id, risk_score, confidence, factors, model_version          |
| Decision      | decision_id, action, policy_version, rationale_refs, human_required                    |
| Case          | case_id, transaction_id, status, analyst_id, created_at, resolution                    |
| AuditEvent    | event_id, actor, object_id, action, timestamp, metadata                                |

**Evidence principle: the LLM may interpret evidence, but it should not invent evidence. Every material claim in the decision should point to an evidence object or an explicit policy rule.**

## 7. API Specifications

| Method | Endpoint                       | Purpose                                 |
|--------|--------------------------------|-----------------------------------------|
| POST   | /v1/transactions/analyze       | Analyze transaction + context           |
| GET    | /v1/transactions/{id}          | Fetch transaction and assessment        |
| GET    | /v1/transactions/{id}/evidence | Return evidence linked to decision      |
| POST   | /v1/communications/analyze     | Analyze message/transcript              |
| POST   | /v1/advisories/search          | Retrieve relevant advisory content      |
| POST   | /v1/decisions/validate         | Validate proposed action against policy |
| POST   | /v1/cases                      | Create human-review case                |
| PATCH  | /v1/cases/{id}                 | Update case status/assignment           |
| GET    | /v1/cases/{id}/audit           | Return case audit history               |
| GET    | /v1/health                     | Health check                            |

### Request example

```
POST /v1/transactions/analyze
{"transaction_id":"txn_018","customer_id":"cust_1042","amount":15000,"currency":"USD","destination_country":"SG","communication_ids":["comm_771"]}
```

### Response example

```
{"transaction_id":"txn_018","risk_score":92,"confidence":0.88,"recommended_action":"HOLD_AND_ESCALATE","human_required":true,"factors":["coercive_language","unusual_destination","advisory_match"],"policy_version":"policy-1.2","trace_id":"prism-abc123"}
```

## API requirements

- JSON schema validation and stable enums for actions/statuses.
- Idempotent analysis keyed by transaction and analysis version.
- Sensitive fields minimized in logs and responses.
- Every AI decision carries trace\_id, model\_version and policy\_version.
- Production deployment should use OIDC/OAuth2, RBAC, rate limiting and service authentication.

## 8. Security & Compliance Plan

| Area          | Hackathon control           | Production direction                                     |
|---------------|-----------------------------|----------------------------------------------------------|
| Identity      | Demo roles                  | OIDC/SAML + MFA + RBAC/ABAC                              |
| Data          | Synthetic records only      | Encryption + classification + retention controls         |
| Secrets       | Environment variables       | Vault/KMS + rotation                                     |
| AI            | Bounded tools + policy gate | Model allowlists + prompt-injection defense + eval gates |
| Audit         | Decision event log          | Append-only / tamper-evident audit storage               |
| Access        | Analyst/admin split         | Least privilege + privileged-access monitoring           |
| Third parties | Documented providers        | Vendor risk assessment + contractual controls            |

### Threat model

- Prompt injection inside customer messages or retrieved documents.
- Tool misuse or unauthorized data access.
- Evidence poisoning, stale advisories or misleading retrieval.
- LLM hallucination or unsupported justification.
- Credential/API abuse and insider misuse.
- False positives causing customer friction.
- False negatives causing financial loss.

### Required safeguards

- Treat all external text as untrusted data.
- Separate evidence from instructions and never allow retrieved text to redefine system policy.
- Use allowlisted, typed tools with hard limits.
- Use deterministic policy validation before consequential actions.
- Require human approval for configured high-risk/high-value classes.
- Record evidence provenance and policy/model versions.
- Use formal compliance/legal review before any production banking deployment.

## 9. PRISM Evaluation Strategy

PRISM is a core engineering loop rather than a final screenshot. V1 should be the strongest reasonable implementation within the available time. We do not intentionally remove capabilities just to manufacture a failure.

| Metric / Evaluator   | Checks                                      | Prototype target |
|----------------------|---------------------------------------------|------------------|
| Decision correctness | Action matches scenario ground truth/policy | ≥90%             |

| Metric / Evaluator         | Checks                                | Prototype target |
|----------------------------|---------------------------------------|------------------|
| Critical evidence coverage | Required evidence is considered       | ≥95%             |
| Policy adherence           | Final action obeys deterministic gate | 100%             |
| Loop/tool discipline       | No unbounded calls or retries         | 0 unbounded runs |
| Grounded rationale         | Claims map to evidence                | ≥95%             |
| Escalation safety          | High-impact uncertainty reaches human | 100%             |
| Latency                    | End-to-end analysis                   | <10 s typical    |

## Example PRISM discovery → fix

- V1 performs correctly on many cases but a trace shows it retrieves a critical advisory and fails to include that evidence in the final decision.
- Root cause: retrieval output is optional in the reasoning state.
- Fix: make critical evidence coverage a mandatory state transition before a decision can be proposed.
- V2 reruns the identical scenario cohort.
- Final pitch shows the trace and before/after evaluator result rather than a fabricated failure.

# 10. Project Roadmap & Timeline

| Phase       | Time    | Deliverables                          | Exit criterion           |
|-------------|---------|---------------------------------------|--------------------------|
| Setup       | 0-2 h   | Repo, schema, UI shell, architecture  | Skeleton runs            |
| V1 Core     | 2-7 h   | Transaction pipeline + action gate    | One complete scenario    |
| Context     | 7-11 h  | Communication + RAG                   | Evidence visible in case |
| UX          | 11-15 h | Dashboard + case screens              | Polished analyst flow    |
| PRISM       | 15-18 h | Traces + evaluators + scenario cohort | Real failure observed    |
| Remediation | 18-21 h | Root-cause fix + regression           | V2 improves              |
| Polish      | 21-24 h | Demo, metrics, pitch                  | Reliable 5-min demo      |

## Post-hackathon

- M1: stronger datasets, evaluation harness and model abstraction.
- M2: secure event ingestion and production-grade identity.
- M3: institution-specific policies and workflow integration.
- M4: sandbox pilot with formal security/model-risk review.
- M5+: governance, continuous evaluation and production readiness.

# 11. Go-to-Market Plan

The first target customer is a financial institution or fintech that already has transaction monitoring but wants stronger contextual understanding of social-engineering incidents.

| Stage           | Target                        | Offer                                 | Success signal                 |
|-----------------|-------------------------------|---------------------------------------|--------------------------------|
| Design partners | Fintech / small-bank teams    | Sandbox contextual fraud analysis     | Analyst validation             |
| Pilot           | Fraud operations              | Limited workflow integration          | Review time + evidence quality |
| Expansion       | Mid/large institutions        | Policy-aware case orchestration       | Higher analyst throughput      |
| Platform        | Risk/compliance organizations | Continuous AI evaluation + governance | Recurring usage                |

**Positioning: LedgerSentinel is not another fraud score. It is a context-aware fraud-response agent with bounded autonomy.**

Business model hypothesis: paid pilot followed by usage-based/API pricing, with enterprise tiers for workflow integration, governance and continuous AI evaluation. Pricing must be validated through customer discovery.

Initial acquisition: fintech partnerships, banking innovation programs, fraud-risk communities, security/AI conferences, developer pilots and evidence-driven case studies.

## 12. Tracking & Analytics Plan

| Category | Event              | Key properties                    | Purpose                 |
|----------|--------------------|-----------------------------------|-------------------------|
| Product  | analysis_completed | risk, confidence, action, latency | Core performance        |
| Evidence | evidence_attached  | source, relevance, confidence     | Evidence quality        |
| Workflow | case_opened        | risk_band, trigger                | Analyst workload        |
| Workflow | case_resolved      | resolution, duration              | Operational value       |
| Safety   | human_escalation   | risk, confidence, reason          | Bounded autonomy        |
| AI       | tool_call          | tool, duration, success           | Loop/latency detection  |
| PRISM    | evaluation_run     | cohort, version, score            | Regression tracking     |
| Security | policy_denied      | rule_id, proposed_action          | Unsafe-action detection |

**North-star metric: Contextually Safe Resolution Rate — the percentage of evaluated cases where the system selects a policy-compliant action appropriately calibrated to the evidence.**

Supporting KPIs: false-positive rate, false-negative rate, critical-evidence coverage, escalation precision, analyst time per case, latency, tool-call count, unsupported-claim rate, PRISM evaluator pass rate and regression rate.

## 13. Full Product Requirements Document (PRD)

Product: LedgerSentinel

Type: AI-assisted fraud detection + bounded-response agent

Platform: Web analyst console + REST API

Primary objective: detect contextual social-engineering risk while preventing unsafe automation.

### Product hypothesis

Combining structured transaction data with unstructured communications and public fraud guidance should improve contextual fraud detection compared with transaction-only analysis. Separating risk from confidence and routing decisions through a deterministic policy gate should reduce unsafe autonomous actions.

### Functional requirements

| ID    | Requirement            | Priority | Acceptance criterion                                   |
|-------|------------------------|----------|--------------------------------------------------------|
| FR-01 | Transaction intake     | P0       | Valid synthetic transaction produces an analysis trace |
| FR-02 | Communication analysis | P0       | Risk signals are extracted and linked to evidence      |
| FR-03 | Advisory retrieval     | P0       | Relevant public material is returned with provenance   |
| FR-04 | Evidence fusion        | P0       | Decision shows multiple contributing factors           |

| ID    | Requirement       | Priority | Acceptance criterion                             |
|-------|-------------------|----------|--------------------------------------------------|
| FR-05 | Risk + confidence | P0       | Both values are separately visible               |
| FR-06 | Action gate       | P0       | Unsafe AI proposal is rejected by policy         |
| FR-07 | Human escalation  | P0       | High-impact uncertainty creates a case           |
| FR-08 | Audit trail       | P0       | Decision stores evidence/model/policy references |
| FR-09 | PRISM trace       | P0       | Agent trajectory is observable/evaluable         |
| FR-10 | Regression        | P1       | Same scenario cohort can be rerun                |
| FR-11 | Dashboard         | P1       | Analyst sees portfolio and recent cases          |
| FR-12 | Verification      | P1       | Case can enter a verification state              |

## Non-functional requirements

- Reliability: every agent run reaches a known terminal state.
- Explainability: recommendations reference evidence and policy.
- Security: no production credentials or PII in the hackathon build.
- Performance: typical prototype analysis under 10 seconds.
- Observability: model, prompt, tool, retrieval and policy versions traceable.
- Maintainability: policy logic is configurable rather than hidden in prompts.
- Accessibility: status communicated with text/icons as well as color.
- Reproducibility: scenario IDs and evaluation cohorts remain stable.

# 14. Key User Journeys & Demo Script

## Journey A — Social-engineering transfer

- Customer initiates a large international transfer.
- Transaction-only signals appear plausible.
- Linked call/message contains urgency, coercion or impersonation language.
- Advisory retrieval finds relevant public guidance.
- Evidence fusion raises risk and/or reduces confidence.
- Policy gate moves the case to HOLD + HUMAN ESCALATION.
- Analyst opens the case and sees the evidence behind the recommendation.

## Journey B — Legitimate overseas transaction

- Customer is traveling and makes an unusual but legitimate purchase.
- Location is abnormal, but history and context support legitimacy.
- No coercive communication evidence exists.
- System approves or requests proportionate verification instead of blindly blocking.

## Journey C — PRISM improvement

- Run realistic cohort against V1.
- PRISM exposes an actual weakness.
- Team diagnoses root cause and makes a concrete architectural/policy change.
- Rerun the same cohort against V2.
- Show trace comparison and metric improvement in the final presentation.

# 15. Evaluation Scenario Matrix

| ID  | Scenario                             | Expected action    | Key evidence                           |
|-----|--------------------------------------|--------------------|----------------------------------------|
| S01 | Coercive scam + large transfer       | Hold + escalate    | Urgency, impersonation, advisory match |
| S02 | Investment scam + repeated transfers | Verify / hold      | Pattern + communication                |
| S03 | Fake bank support + remote access    | Hold + escalate    | Remote-access request                  |
| S04 | Legitimate overseas travel           | Approve / verify   | Travel + clean history                 |
| S05 | High-value known business supplier   | Verify             | Expected counterparty                  |
| S06 | Conflicting high-impact evidence     | Human escalation   | Low confidence + high impact           |
| S07 | Retrieval unavailable                | Safe fallback      | Missing evidence                       |
| S08 | Prompt injection in message          | Ignore instruction | Untrusted input                        |

## 16. Hackathon Team Implementation Plan

| Role                     | Ownership                                                           |
|--------------------------|---------------------------------------------------------------------|
| AI / Agent               | LangGraph workflow, extraction, reasoning, evidence schema, prompts |
| Backend                  | FastAPI, data model, policy gate, synthetic fixtures                |
| Frontend                 | Dashboard, transaction, case, verification and PRISM screens        |
| Evaluation / Integration | Scenario cohort, PRISM evaluators, metrics, regression, pitch       |

**Build-order rule: get one complete vertical slice working early. The minimum slice is transaction → communication evidence → risk/confidence → policy gate → case screen.**

## 17. Risks, Trade-offs & Mitigations

| Risk                 | Impact | Mitigation                                             |
|----------------------|--------|--------------------------------------------------------|
| LLM hallucination    | High   | Evidence schema + provenance + deterministic gate      |
| False positives      | High   | Tiered actions + legitimate scenarios                  |
| False negatives      | High   | Context fusion + broad scenario coverage               |
| Agent loops          | Medium | Explicit state machine + budgets                       |
| Stale retrieval      | Medium | Source metadata + freshness + curated corpus           |
| Demo instability     | High   | Synthetic fixtures + deterministic fallbacks           |
| Scope creep          | High   | No real banking integration; prioritize vertical slice |
| Compliance overclaim | High   | Prototype disclaimer + formal production review        |

## 18. Definition of Done

- A synthetic transaction can be analyzed end-to-end.
- At least three communication scenarios contribute meaningful evidence.
- Relevant public advisory content can be retrieved with provenance.
- Risk and confidence are separately displayed.
- Approve, verify, hold and human escalation are implemented.
- High-impact recommendations are constrained by deterministic policy.
- Analysts can inspect transaction, evidence, decision and audit history.
- PRISM captures agent behavior and evaluator results.

- At least one genuine PRISM-discovered issue is remediated.
- The identical scenario cohort demonstrates measurable V2 improvement.
- The complete demo is stable and can be presented in five minutes or less.

## Appendix A — Prototype Policy & Technical Notes

| Condition                                                | Illustrative action             |
|----------------------------------------------------------|---------------------------------|
| Risk < 30 AND confidence ≥ 0.75 AND no critical evidence | APPROVE                         |
| 30-59 OR confidence < 0.75                               | VERIFY                          |
| 60-84 OR high-impact anomaly                             | HOLD                            |
| Risk ≥ 85 OR critical scam evidence                      | HOLD + HUMAN ESCALATION         |
| Any policy violation by AI proposal                      | REJECT PROPOSAL + SAFE FALLBACK |

These thresholds are illustrative prototype values, not banking rules. Production thresholds would require historical validation, institution-specific policy, model-risk governance and compliance approval.

## Appendix B — Product principles

- AI proposes; deterministic policy authorizes.
- Uncertainty should reduce autonomy.
- Evidence must be traceable.
- External text is untrusted input.
- High-impact actions require stronger safeguards.
- PRISM should reveal real weaknesses, not manufactured ones.
- Improvement is demonstrated with the same evaluation cohort.

END OF DOCUMENT